

Documentation

Simulation MQTT Sécurisée

Mai 2026

1 Prérequis

L'environnement doit disposer de Python 3.x et du broker Mosquitto.

```
pip install paho-mqtt cryptography
```

2 Déploiement et Exécution

Cette section détaille les commandes exactes à lancer pour reproduire la simulation de vente. Il est conseillé d'ouvrir au minimum 3 terminaux distincts.

2.1 Étape 1 : Lancement du Broker MQTT

Dans le premier terminal, démarrer Mosquitto en mode verbeux pour observer le routage :

```
mosquitto -v
```

Attendu : Mosquitto écoute sur le port 1883.

2.2 Étape 2 : Initialisation de la PKI

Dans le deuxième terminal, générer le matériel cryptographique (à ne faire qu'une fois) :

```
python gen_keys.py
```

Attendu : Création des fichiers `server_private_key.pem`, `server_public_key.pem` et `server_certificate.pem`.

2.3 Étape 3 : Démarrage du Vendeur

Toujours dans le même terminal (ou un troisième), lancer le serveur :

```
python serveur.py
```

Attendu : Affichage "Connecté au broker MQTT" et "En attente de clients..."

2.4 Étape 4 : Démarrage de l'Acheteur (Mode Interactif)

Dans un nouveau terminal, lancer le client :

```
python client.py
```

Attendu : Le handshake s'effectue automatiquement. Le terminal affiche "Certificat serveur reçu", "Clé de session AES générée", puis débloque le menu interactif proposant d'acheter un produit ou de voir le catalogue.

3 Mécanique du Certificat X.509

Contrairement à un simple échange de clés publiques brutes, notre implémentation utilise un certificat X.509. Lors de la réception du message **CERT**, le client exécute `load_server_certificate()`.

Cette étape permet théoriquement d'extraire et de valider les champs suivants :

- **Common Name (CN)** : On vérifie que l'identité déclarée (VendeurServeur) correspond bien à l'entité avec laquelle on souhaite communiquer.
- **Période de validité** : Les attributs `not_valid_before` et `not_valid_after` permettent de s'assurer que le certificat n'est pas expiré.
- **Signature** : Assure que le certificat n'a pas été falsifié.

Bien que notre vérification soit basique (autosignature), le certificat X.509 est en place et montre la faisabilité d'une intégration avec une véritable Autorité de Certification (PKI).